

ALIGN INFORMATION SECURITY MANAGEMENT SYSTEM

POLICY SUITE (ISO/IEC 27001:2022 ALIGNED)

Organization: Align by Abode

Document Type: Information Security Governance Framework

Version: 1.0

Classification: Internal Use Only

Compliance Targets: ISO/IEC 27001:2022, Nigeria Data Protection Act (NDPA 2023), NITDA

Guidelines

Owner: Head of Information Security & Compliance

Approval Authority: Executive Management

By: Wilson C. Nometa

TABLE OF CONTENTS

1. Information Security Policy (Master Policy)
2. Access Control Policy
3. Acceptable Use Policy (AUP)
4. Data Classification & Handling Policy
5. Password & Authentication Policy
6. Incident Response Policy
7. Risk Management Policy
8. Asset Management Policy
9. Network Security Policy
10. Endpoint Security Policy
11. Backup & Disaster Recovery Policy
12. Third-Party & Vendor Security Policy
13. Logging & Monitoring Policy
14. Business Continuity Policy
15. Compliance & Audit Policy

1. INFORMATION SECURITY POLICY

(MASTER POLICY)

Purpose

This policy defines Align's commitment to protecting information assets against unauthorized access, disclosure, alteration, and destruction.

Scope

Applies to all employees, contractors, systems, infrastructure, and data owned or processed by Align.

Policy Statement

- Information security is a business priority and must be embedded in all operations.
- Align adopts a risk based approach to security management.
- All employees are responsible for safeguarding information assets.
- Security controls must comply with ISO 27001 and Nigerian regulatory requirements.

Enforcement

Violations may result in disciplinary action, termination, or legal proceedings.

2. ACCESS CONTROL POLICY

(Condensed upgraded version of previous policy)

- Access must be role-based (RBAC).
 - MFA is mandatory for all critical systems.
 - The least privilege principle must be enforced.
 - Access must be reviewed every 90 days.
 - Immediate deprovisioning of all logical credentials and cloud access tokens **within a maximum of two (2) hours** from official HR notification of employee or contractor exit.
-

3. ACCEPTABLE USE POLICY (AUP)

Purpose

Defines acceptable use of Align systems and resources.

Policy

- Systems must only be used for authorized business purposes.
- Personal use of corporate systems must be minimal and not impact performance.
- Users must not:
 - Install unauthorized software
 - Access illegal or harmful content
 - Attempt to bypass security controls
 - Share credentials
- Company devices remain property of Align.

Monitoring

All activity may be monitored for security and compliance purposes.

4. DATA CLASSIFICATION & HANDLING

POLICY

Data Protection Impact Assessments (DPIAs): In strict compliance with Section 24 of the Nigeria Data Protection Act (NDPA) 2023, the Data Protection Officer (DPO) must conduct and document a formal DPIA prior to the deployment of any automated identity verification mechanisms, tenant screening algorithms, or profiling modules within the Align marketplace ecosystem.

Processing Legitimacy: All processing of restricted personal data—including candidate verification metrics, government-issued identification numbers, and banking details—must be justified by a documented legal basis (such as explicit user consent or contractual necessity).

Data Controller Registrations: Align by Abode shall maintain an active registration status as a Data Controller of Major Importance with the Nigeria Data Protection Commission (NDPC), filing annual data protection compliance audit returns as mandated by statutory timelines.

Data Categories

- Public
- Internal
- Confidential
- Restricted (Financial, customer, authentication data)

Rules

- Restricted data must be encrypted at rest and in transit.
- Confidential data must not be shared externally without approval.
- Data must be stored only in approved systems.
- NDPA-compliant consent must be obtained for personal data processing.

5. PASSWORD & AUTHENTICATION

POLICY

- Minimum password length: 12 characters
- Passwords must include complexity requirements
- Password reuse is prohibited
- MFA is **strictly mandatory for all accounts** across the corporate directory ecosystem, including standard workspace email access, staging/production cloud scopes, and developer repositories.
- Credentials must never be shared
- Passwords must be stored only in approved password managers

6. INCIDENT RESPONSE POLICY

Stages

1. Identification
2. Containment
3. Eradication
4. Recovery
5. Lessons Learned

Requirements

- All incidents must be reported within 1 hour of detection.
- Security incidents must be logged in an incident register.
- Evidence must be preserved for forensic analysis.
- Regulatory notification must follow NDPA requirements where applicable.

7. RISK MANAGEMENT POLICY

- Risk assessments must be conducted quarterly.
- Risks must be rated based on likelihood and impact.
- Treatment options: avoid, mitigate, transfer, accept.
- Risk register must be maintained and reviewed by management.
- High risks require executive approval.

8. ASSET MANAGEMENT POLICY

- All assets must be inventoried and tagged.
- Asset ownership must be assigned.
- Unauthorized assets are prohibited.
- Asset lifecycle includes: procurement → use → disposal.
- Secure disposal is required for all storage devices.

9. NETWORK SECURITY POLICY

- Firewalls must be implemented at all network boundaries.
- Network traffic must be monitored.
- Segmentation must separate production and internal systems.
- Public Wi-Fi must not be used for sensitive operations.
- Remote access must use VPN encryption.

10. ENDPOINT SECURITY POLICY

- All endpoints must have antivirus/EDR installed.
- Devices must be encrypted.
- USB usage must be restricted.
- Automatic screen lock must activate after a maximum of three (3) minutes of system inactivity on all corporate laptops and endpoints (The Industry Standard: Under ISO/IEC 27001 Control A.7.7 (Clear Desk and Clear Screen), a 10-minute unattended window leaves office hardware or remote endpoints wide open to unauthorized physical access).
- Security patches must be applied within defined SLA timelines.

11. BACKUP & DISASTER RECOVERY POLICY

- Critical data must be backed up daily.
- Backups must be encrypted and stored offsite/cloud.
- Recovery testing must be performed quarterly.
- Recovery Time Objective (RTO) and Recovery Point Objective (RPO) must be defined per system.

12. THIRD-PARTY & VENDOR SECURITY

POLICY

- Vendors must undergo security assessment before onboarding.
- Contracts must include confidentiality and data protection clauses.
- Vendors must comply with NDPA and ISO 27001 expectations.
- Access must be time-bound and monitored.

Independent Security Attestations: Align by Abode restricts onboarding to third-party vendors, suppliers, and external contractors who handle or host corporate information assets to those who pass a formal security evaluation.

Cloud Hosting Infrastructure Mandates: Any external cross-border cloud hosting partner or infrastructure-as-a-service (IaaS) node provisioning environments for Align production instances must present a verified, valid ISO/IEC 27001:2022 Certificate or a SOC 2 Type II Attestation Report covering the security, confidentiality, and availability trust principles.

Fintech & Payment Gateway Integration: In alignment with the Central Bank of Nigeria (CBN) Anti-Money Laundering & Digital Payment Monitoring Policies, all payment aggregators and escrow transaction nodes integrated into the platform must maintain an active PCI-DSS (Payment Card Industry Data Security Standard) certification.

Contractual Safeguards: All vendor contracts must include binding Data Processing Agreements (DPAs) containing explicit confidentiality clauses, breach notification SLAs (requiring notification to Align's CISO within 24 hours of a security event), and right-to-audit provisions.

13. LOGGING & MONITORING POLICY

- Security logs must be generated for all critical systems.
- Logs must be retained for a minimum 12 months.
- Logs must be protected from tampering.
- Continuous monitoring for suspicious activity is mandatory.
- Alerts must be escalated to the security team.

14. BUSINESS CONTINUITY POLICY

- Business continuity plans must be documented and tested annually.
- Critical systems must have redundancy.
- Disaster recovery procedures must be clearly defined.
- Staff must be trained on continuity procedures.

15. COMPLIANCE & AUDIT POLICY

- Align must comply with ISO 27001, NDPA 2023, and NITDA regulations.
- Internal audits must be conducted annually.
- External audits may be conducted by regulators or partners.
- Non-compliance must be tracked and remediated.